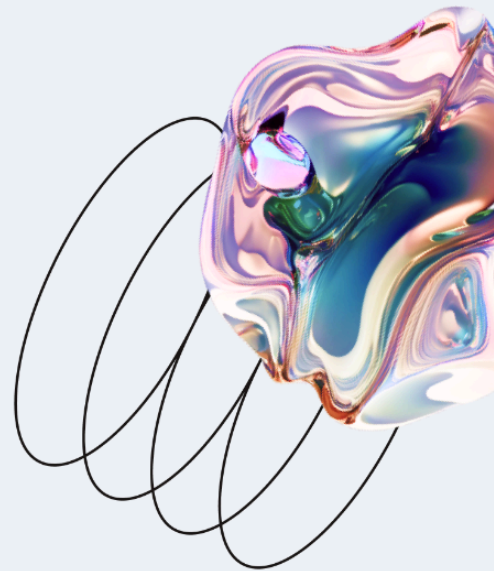




Основы криптографической защиты информации

Основы информационной
безопасности



Оглавление

Введение.....	3
Словарь терминов.....	3
Криптография как отдельная наука и направление в области обеспечения ИБ.....	3
Основные криптосистемы и их компоненты.....	6
Симметричное шифрование.....	6
Асимметричное шифрование.....	8
Хэш-функция.....	11
Электронная подпись.....	12
Инфраструктура открытых ключей.....	14
Практика применения криптографической защиты информации.....	17
Средства криптографической защиты информации (СКЗИ).....	17
Практика применения СКЗИ.....	18
Атаки на криптосистемы.....	20
Современные протоколы шифрования.....	21
Система сертификации средств криптографической защиты информации и особенности применения на территории РФ.....	22
Выводы.....	23
Дополнительные материалы.....	24
Использованная литература.....	24

Введение

Сегодня мы продолжим курс, посвящённый основам обеспечения информационной безопасности (ИБ), а текущее занятие – основы криптографической защиты информации.

На этой лекции вы узнаете:

- Как развивалась криптография, и как она стала отдельной наукой?
- Чем отличается симметричное и асимметричное шифрование?
- Зачем нужна инфраструктура открытых ключей (PKI)?
- Какая есть практика применения криптографической защиты информации при её передаче по каналам связи и при её обработке и хранении?
- О наличии системы сертификации средств криптографической защиты информации.
- Об особенностях криптографической защиты информации на территории РФ.

Словарь терминов

Криптографическое средство защиты информации – средство защиты информации, реализующее алгоритмы криптографического преобразования информации ([ГОСТ Р 50922-2006](#)).

Алгоритм зашифрования – алгоритм, реализующий зашифрование, т.е. преобразующий открытый текст в шифртекст ([ГОСТ 34.12-2018](#)).

Алгоритм расшифрования – алгоритм, реализующий расшифрование, т.е. преобразующий шифртекст в открытый текст ([ГОСТ 34.12-2018](#)).

Открытый текст (plaintext) – незашифрованная информация ([ГОСТ 34.12-2018](#)).

Шифртекст (ciphertext) – данные, полученные в результате зашифрования открытого текста в целях сокрытия его содержания ([ГОСТ 34.12-2018](#)).

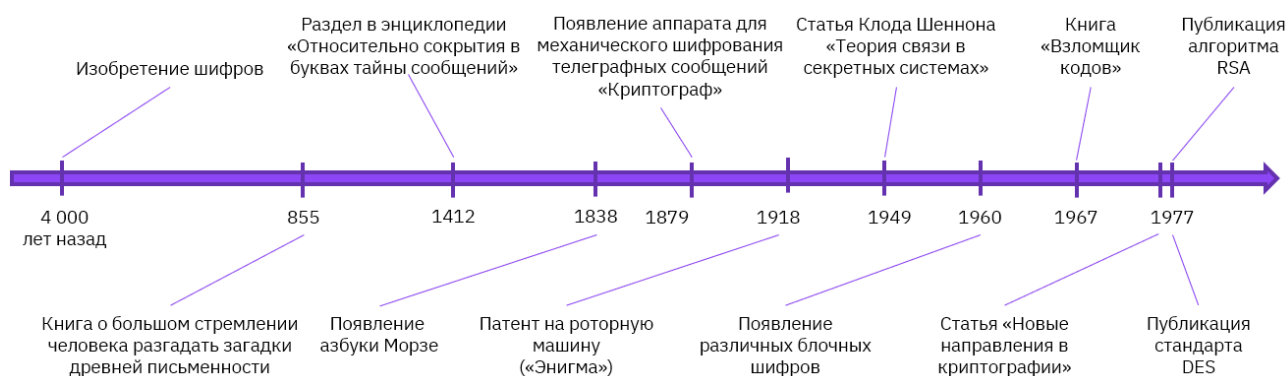
Шифр – криптографический метод, используемый для обеспечения конфиденциальности данных, включающий алгоритм зашифрования и алгоритм расшифрования ([ГОСТ 34.12-2018](#)).

Ключ (key) – изменяемый параметр в виде последовательности символов, определяющий криптографическое преобразование ([ГОСТ 34.12-2018](#)).

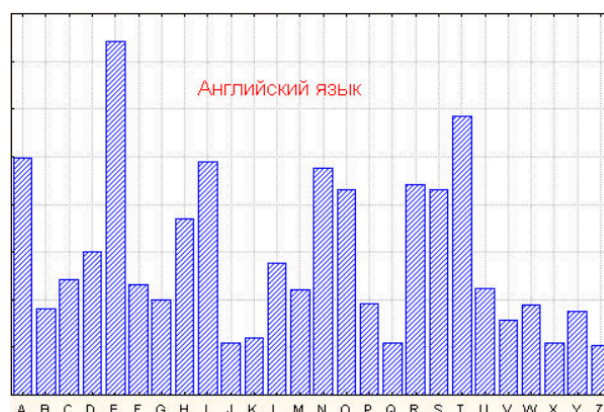
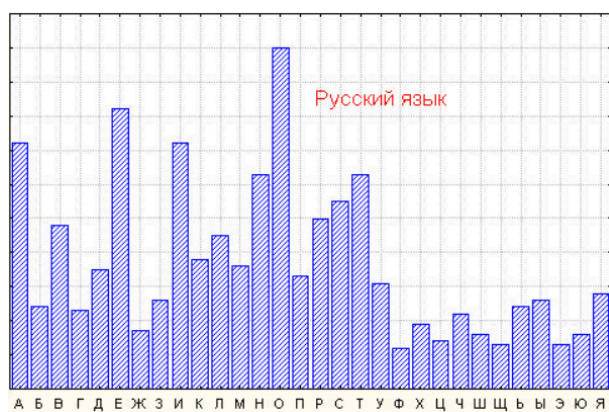
Криптография как отдельная наука и направление в области обеспечения ИБ

Стоит начать с того, что первые шифры появились спустя примерно 1 000 лет после изобретения письменности и развивались в несколько этапов [1].

Упрощённая история криптографии



Началось всё с шифров простой замены (моноалфавитных шифров), когда для каждого символа открытого текста существует сопоставляемый ей символ шифртекста (например, шифр Цезаря, шифр Полибия). «Противоядием» для таких шифров стал частотный криптоанализ, учитывающий, что частотность появления заданной буквы (символа) алфавита в достаточно длинных текстах такая же, как в других текстах на данном языке (алфавите) [2].



Развитием данных шифров стали полиалфавитные шифры (многоалфавитные шифры, например, шифр Виженера, шифр Гронсфельда), когда к первому символу применяется первый моноалфавитный шифр, ко второму символу – второй шифр, к

третьему – третий, и в определённый момент (когда кончится набор моноалфавитных шифров) вновь первый, второй и так далее.

Стремительное развитие криптография получила в XX веке:

- первая его половина характеризуется появлением электромеханических агрегатов, использующих принципы криптографического диска/ротора (например, шифровальные машины Хеберна (США), Шербиуса (Германия, «Энигма») и другие);
- вторая его половина – это переход к математической криптографии, фактически становление её как отдельной науки после публикации Клода Шеннона «Теория связи в секретных системах».

Здесь возникло понятие *идеальный шифр* – это шифр, который полностью скрывает в шифртексте все статистические закономерности открытого текста.



Ещё в 1883 году математик и криптограф Огюст Керкгоффс сформулировал ряд правил, которые перефразировав можно свести к следующему: «Стойкость шифра определяется только секретностью ключа, а не секретностью алгоритма шифрования».

Условно, можно выделить следующие основные области практического применения криптографии:

- в обеспечении конфиденциальности информации как передаваемой, так и хранимой;
- в обеспечении целостности информации как передаваемой, так и хранимой;
- обеспечение неотказуемости действий субъекта доступа (пользователя систем);
- реализация механизмов аутентификации субъектов доступа;
- обеспечение аутентичности (подлинности) отправителя сообщения¹.

Шифры можно условно можно разделить на следующие классы:

- по типу преобразования:
 - шифры замены;
 - шифры перестановки;
 - композитные шифры;

¹ В рамках инфраструктуры открытых ключей.

- по особенностям алгоритма шифрования:
 - одноключевые (симметричные);
 - двухключевые (асимметричные);
- по шифруемой / расшифровываемой порции данных:
 - 1 буква алфавита или 1 бит сообщения: поточные шифры;
 - блоки фиксированной длины: блочные шифры.

В качестве первичного признака, по которому производится классификация шифров, используется тип преобразования открытого текста. Если фрагменты открытого текста (отдельная буква(ы)) заменяются некоторыми их эквивалентами в шифртексте (но позиции букв в шифровке остаются теми же), то шифр относится к классу *шифров замены*. Если буквы открытого текста меняются местами друг с другом (все буквы открытого текста остаются в шифртексте, но в других местах), то шифр относится к классу *шифров перестановки*.

С целью повышения надёжности шифрования шифртекст, полученный применением одного шифра, может быть ещё раз зашифрован с помощью другого шифра. Все возможные такие комбинации шифров приводят к третьему классу шифров – *композиционные шифры*.

Есть различие шифров в части использования ключей. В одноключевых системах для шифрования и расшифрования используется один и тот же ключ, такой шифр относится к классу *симметричных*. В двухключевых системах для шифрования и расшифрования используется два разных ключа, такой шифр относится к классу *асимметричных*.

В связи с тем, что открытый текст обычно имеет произвольную длину, то он разбивается на порции, и каждая порция шифруется в отдельности. По шифруемой / расшифровываемой порции данных шифры делят на потоковые и блочные. В *потоковых шифрах* преобразование выполняется отдельно над каждым символом (битом) открытого текста, в *блочных шифрах* открытый текст разбивается на блоки фиксированной длины (например: 64 бита, 128 бит), каждый из которых шифруется и расшифровывается отдельно от другого.

Криптография – древнейшее направление в обеспечении безопасности информации, которое активно развивается последние 100 лет. В настоящее время развивается постквантовая криптография – это часть криптографии, которая будет актуальной и при появлении квантовых компьютеров и квантовых атак.

Основные криптосистемы и их компоненты

Симметричное шифрование

Перейдём к рассмотрению симметричного шифрования, так же известного как симметричные криптосистемы или криптосистемы с секретным ключом. Основная идея, лежащая в основе симметричного шифрования (т. е. фактически всех шифров до 1976 – 1977 гг.), такова: группа людей может таким способом записывать сообщения (шифровать их), что они будут непонятны всем остальным.

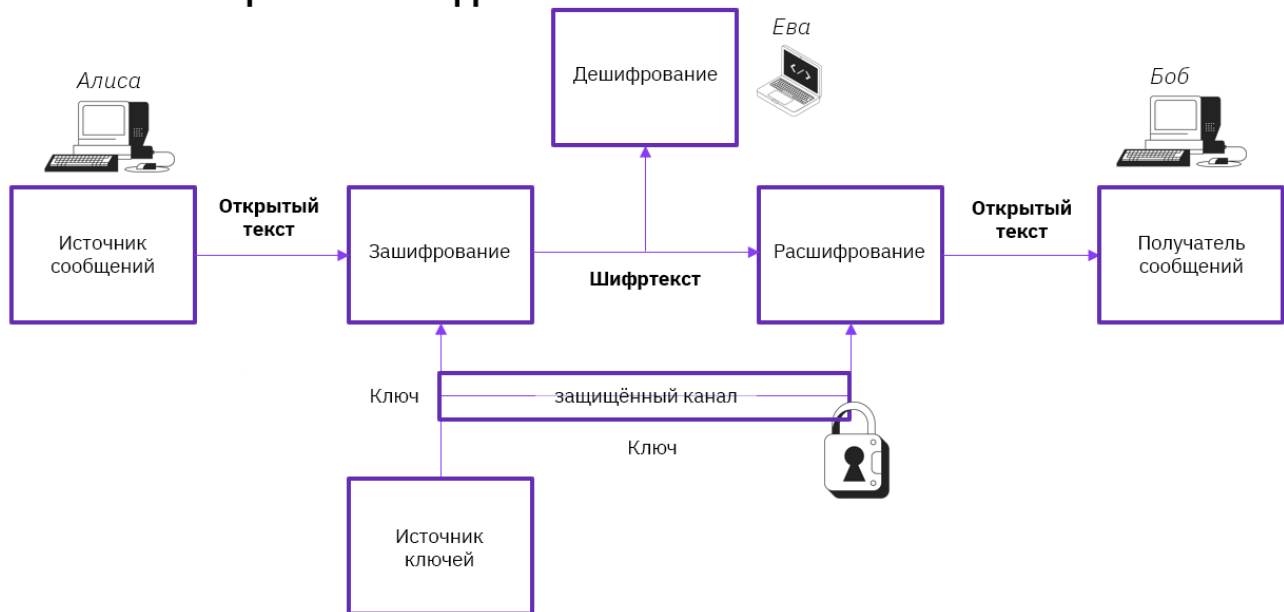
Симметричные шифры относятся к шифрам замены, начнём с примеров исторических и самых простых шифров замены, чтобы понять, как они работают. Открытым текстом будет – «ТЕКСТ», тогда для каждого шифра будем получать соответствующий шифртекст:

- разворот алфавита (шифр Атбаша), шифртекст: «МЪФНМ»;
- сдвиг алфавита на 3 буквы (шифр Цезаря), шифртекст: «ХЗНФХ»;
- квадратный шифр 6x6 (шифр Полибия, шифр Мирабо), шифртекст: «42 16 26 41 42».

Получив такие шифртексты непосвящённый человек (условная Ева) без ключа, воспримет их абракадаброй, но отправитель (условная Алиса) и получатель (условный Боб) всё поймут, т. к. у них есть ключ. Если Ева более настойчивая, то она займётся криптоанализом, о нём мы поговорим чуть позже.

Схема симметричного шифрования представлена на рисунке ниже:

Схема симметричного шифрования



Примеры популярных симметричных шифров:

- ГОСТ 34.12-2018 [3] (длина ключа 256 бит):
 - блочный шифр «Магма»: блоки 64 бита;
 - блочный шифр «Кузнечик»: блоки 128 бит;
- Data Encryption Standard / DES (блоки 64 бита, длина ключа 56 бит);
- Triple DES (блоки 64 бита, длина ключа 168 бит);
- International Data Encryption Algorithm / IDEA (блоки 64 бита, длина ключа 128 бит);
- Advanced Encryption Standard / AES (блоки 128 бит, длина ключа 128/192/256 бит).

К достоинствам симметричного шифрования можно отнести:

- высокую скорость шифрования;
- небольшую длину ключа;
- большую изученность и простоту реализации.

Но есть и недостатки:

- самый серьёзный – это необходимость организации защищённого канала для распространения ключей, т.к. без них, обмен шифртекстами не имеет смысла;
- сложность управления ключами в большой сети участников взаимодействия, если мы будем использовать отдельный ключ на каждый вариант парного взаимодействия;



Формула для получения возможного количества пар из общего числа участников взаимодействия: $[\text{Кол-во пар}] = ([\text{Кол-во участников}] * [\text{Кол-во участников} - 1]) / 2$.

Таким образом, для 10 участников потребуется 45 ключей, а для 100 участников – 4 950 ключей.

- разовая компрометация ключа нарушает конфиденциальность всей информации, зашифрованной данным ключом между всеми участниками взаимодействия как в прошлом, так и в будущем (если ключ будет переиспользован).

Асимметричное шифрование постаралось решить указанную проблему – безопасного распространения ключей.

Асимметричное шифрование

Перейдём к рассмотрению асимметричного шифрования, так же известного как асимметричные криптосистемы или криптосистемы с открытым ключом.

Схема асимметричного шифрования представлена на рисунке ниже:

Схема асимметричного шифрования

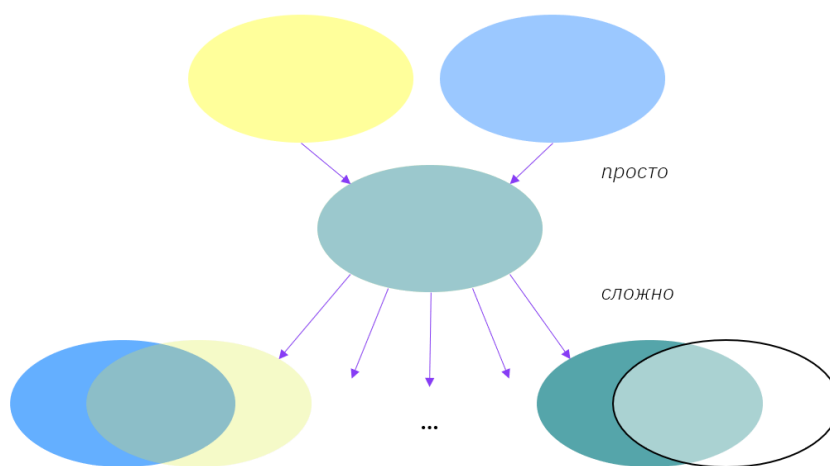


Она позволяет взаимодействовать людям, с которыми вы предварительно не обменялись секретным ключом. Шифрование здесь можно проиллюстрировать следующим образом: Боб возьмёт сейф с кодовым замком, откроет и поставит его где-то, сообщит об этом Алисе (открытый ключ), а Алиса положит туда «сообщение»

и закрывает сейф. В таком случае открыть его сможет только Боб, т. к. он знает код к сейфу (закрытый ключ).

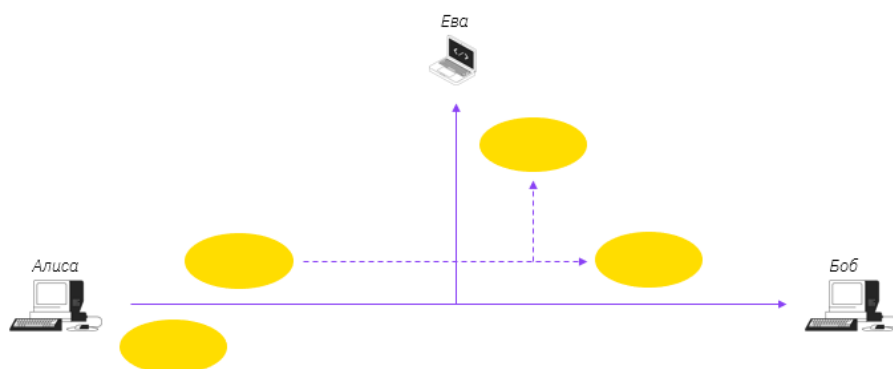
В основе асимметричного шифрования лежат однонаправленные функции, т. е. просто вычисляемые в прямом направлении и принципиально более сложно – в обратном. Например, произведение двух больших чисел VS разложение на множители (факторизация целого числа); модульное возведение в степень VS нахождение дискретного логарифма и другие.

Наиболее просто проиллюстрировать однонаправленные функции можно с помощью смешения двух красок различного цвета:

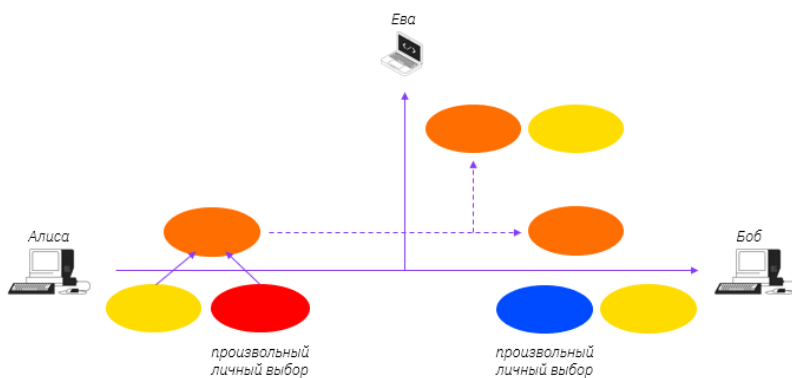


Одной из первых идей применения однонаправленных функций стала схема Диффи-Хеллмана (Diffie-Hellman), которую мы рассмотрим, используя всё те же краски.

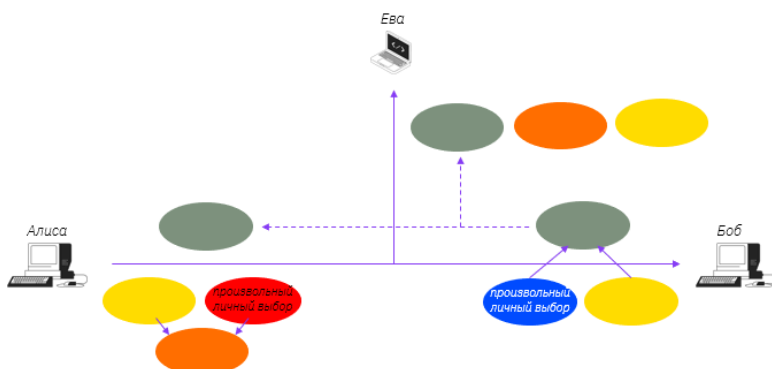
На первых шагах выбираются параметры, которые могут быть сделаны общедоступными (два из трёх компонентов модульного возведения в степень).



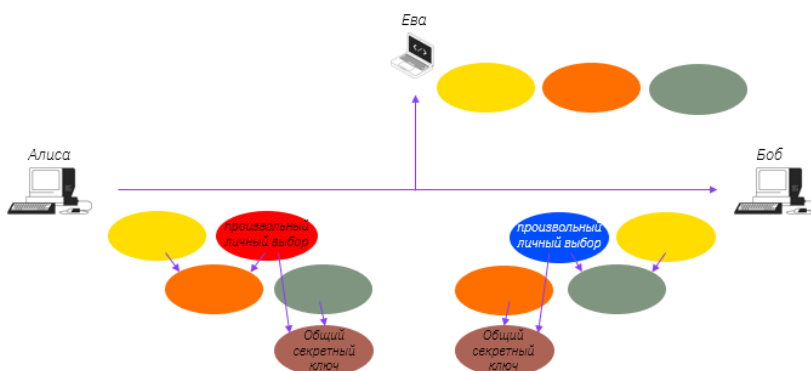
Далее выбираются секретные числа, по одному у Алисы и Боба (третий компонент модульного возведения в степень), и производится расчёт.



И обмен полученными расчётными значениями.



После этого с полученными значениями осуществляется вычисление с использованием своих секретных чисел. Благодаря этому, на каждой стороне получается общий секретный ключ, который никогда не передавался по каналу связи (т. е. недоступен Еве).



Примеры популярных асимметричных шифров:

- ГОСТ 34.10-2018 [4];
- Rivest, Shamir и Adleman / RSA;
- Digital Signature Algorithm / DSA.

Ключевым достоинством асимметричного шифрования является отсутствие необходимости организации защищённого канала для распространения ключей, т. к. возникает открытый ключ.

Но есть и недостатки:

- более низкая скорость шифрования по сравнению с симметричными шифрами;
- большая длина ключа по сравнению с симметричными шифрами;
- меньшая изученность по сравнению с симметричными шифрами;
- сложности с обеспечением аутентичности (подлинности) отправителя сообщения (атака «человек посередине»).

Хеш-функция

Сейчас мы поговорим о функциях, отображающих строки бит, в строки бит фиксированной длины и удовлетворяющие следующим свойствам:

- по данному значению функции сложно вычислить исходные данные, отображаемые в это значение;
- для заданных исходных данных сложно вычислить другие исходные данные, отображаемые в то же значение функции;
- сложно вычислить какую-либо пару исходных данных, отображаемых в одно и то же значение,

это хеш-функции. Примеры хеш-значений:

```
a826aef8dda3fdc8ab5351b0484c47ae
```

```
2a7846db05f522756a68866af953aa9  
82d6f3afd82b1f220b240c4b2de1f206  
b24cc8514443bb5ede30eb7cff05f42fa  
bbfa3376333ea6469c2e34c3d3ac25f5
```

Хеш-функции предназначены для обеспечения целостности информации, точнее, контроля целостности. Они применяются в связке с асимметричными шифрами в так называемой электронной подписи.

Примеры популярных хеш-функций:

- ГОСТ 34.11-2018 [5] (длина хеша 256 или 512 бит)
- MD4 (длина хеша 128 бит)
- MD5* (длина хеша 128 бит)

- MD6 (длина хеша до 512 бит)
- SHA-1* (длина хеша 160 бит)
- SHA-2 (длина хеша 224/256/384/512 бит)
- SHA-3 (длина хеша 224/256/384/512 бит)

 MD5 и SHA-1 устарели и не являются безопасными на сегодняшний день. Хотя, к сожалению, очень часто используются. Не применяйте их в своей практике!

Хеш-функции подвержены коллизиям, т. е. для разных сообщений могут выдать одно хеш-значение. Это обусловлено тем, что множество сообщений бесконечное, а множество хеш-значений – конечное (счётное).

Познакомившись с хеш-функцией, мы можем перейти к понятию электронной подписи, как прикладного аспекта применения асимметричного шифрования.

Электронная подпись

Электронная подпись – информация в электронной форме, которая присоединена к другой информации в электронной форме (подписываемой информации) или иным образом связана с такой информацией и которая используется для определения лица, подписывающего информацию.

 Обратите внимание на три частые ошибки:

1. Использование понятия *электронная цифровая подпись (ЭЦП)*. Федеральный закон, введший это понятие, утратит силу 01 июля 2013 г.
2. Ожидание контроля целостности. Действующее определение *электронной подписи (ЭП)* направлено только на определение лица, подписывающего сообщение.
3. Ожидание конфиденциальности сообщения. Сама по себе электронная подпись не обеспечивает конфиденциальность подписанного сообщения.

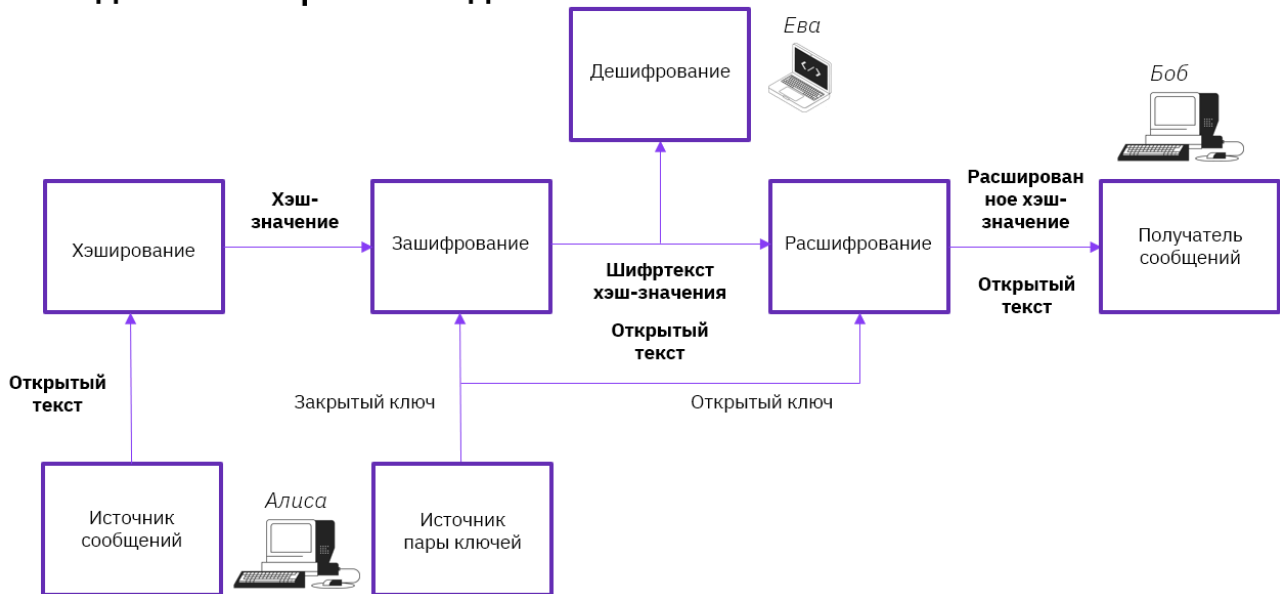
В соответствии с действующим федеральным законодательством [6] выделяют следующие виды электронных подписей:

- простая (использование кодов, паролей и т. п.);

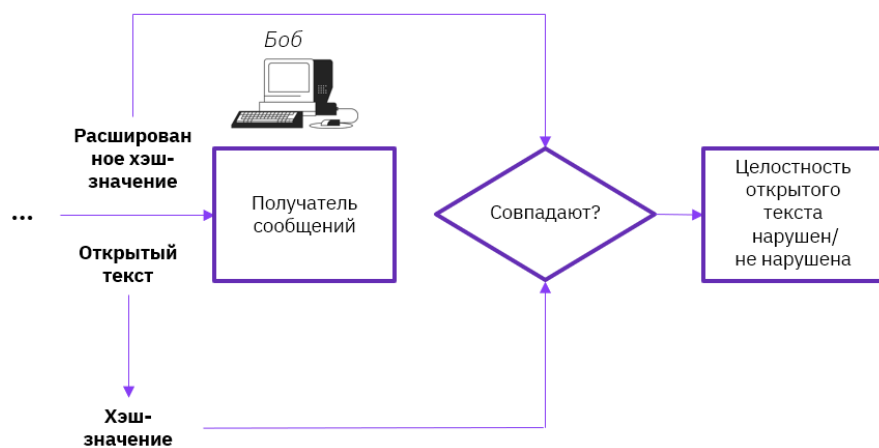
- усиленная (получена в результате криптографического преобразования информации с использованием закрытого ключа):
 - неквалифицированная;
 - квалифицированная.

Схема создания и проверки электронной подписи представлены на рисунках ниже:

Создание электронной подписи



Проверка электронной подписи



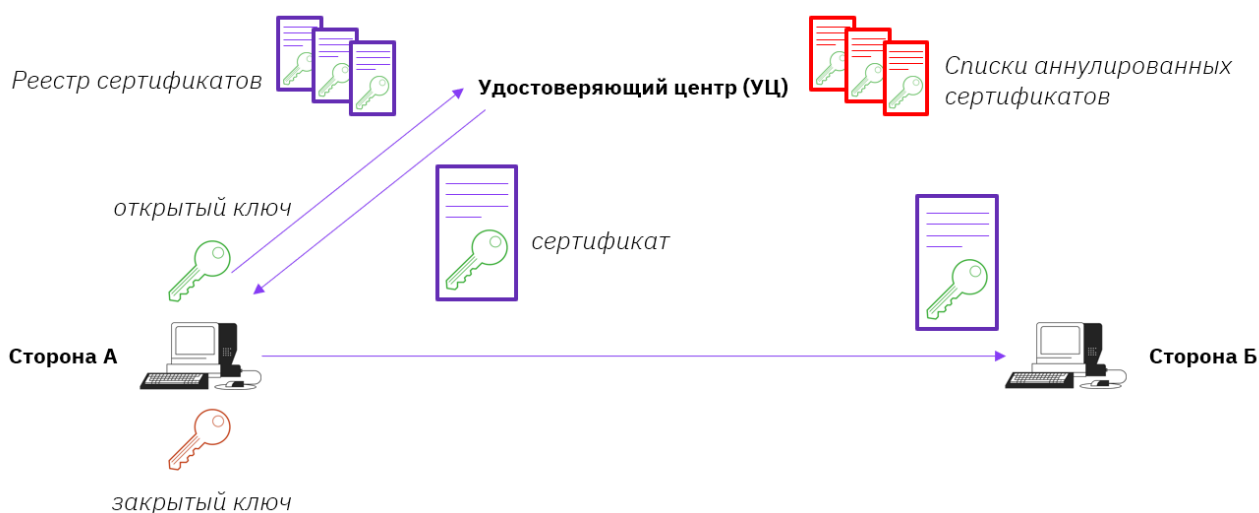
Заключение по блоку симметричного и асимметричного шифрования:

- существует симметричное и асимметричное шифрование – понимайте их достоинства и недостатки (ключевой вопрос в распространении ключей);
- на практике применяются гибридные криптографические схемы:

- обмен ключами с использованием асимметричной криптографии;
- шифрование передаваемых данных с использованием симметричной криптографии;
- хеш-функция является неотъемлемой частью для формирования электронной подписи, но она не обеспечивает конфиденциальность сообщения (открытого текста);
- сами по себе шифры не обеспечивают аутентичность (подлинность) отправителя сообщения.

Инфраструктура открытых ключей

Инфраструктура открытых ключей (Public Key Infrastructure (PKI)) постаралась решить проблему использования асимметричного шифрования в части доверия стороне, с которой идёт взаимодействие (при условии, что до этого вы с ней никогда не встречались).



Инфраструктура открытых ключей (Public Key Infrastructure (PKI)) – это совокупность технологий, политик и процедур, необходимых для создания, управления, распространения, использования, хранения и отзыва сертификатов.

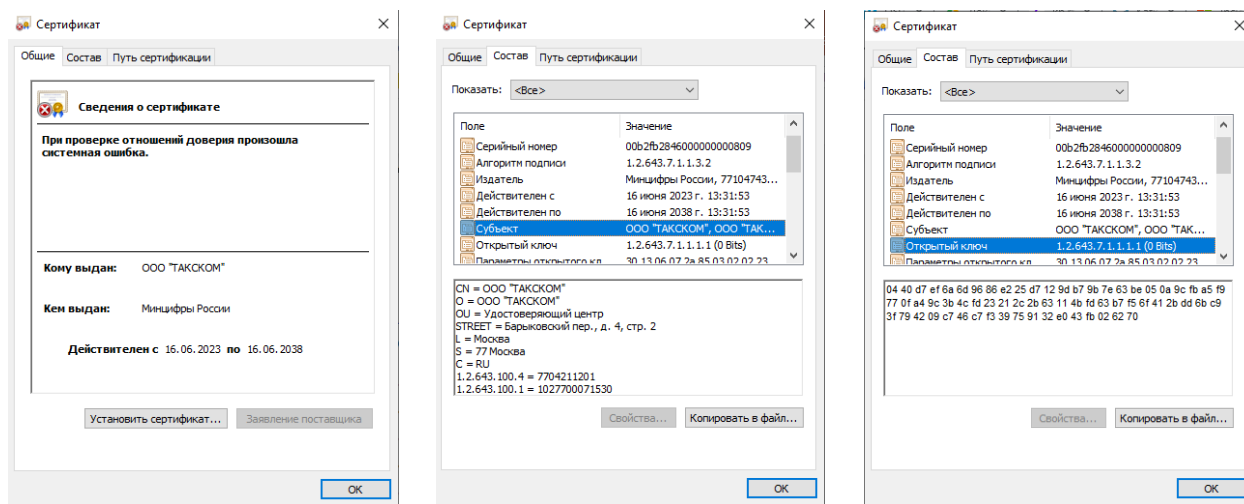
Сертификат – электронный документ или документ на бумажном носителе, выданный удостоверяющим центром и подтверждающий принадлежность открытого ключа владельцу сертификата. А сам удостоверяющий центр (Certification Authority (CA)) – организация, осуществляющая функции по созданию, выдаче и отзыву сертификатов. За счёт третьей авторитетной стороны в лице удостоверяющего центра и создаётся это доверие.

Условно можно выделить следующие основные функции удостоверяющего центра:

- создание сертификатов;
- установление сроков действия сертификатов;
- аннулирование (отзыв) сертификатов, выданных этим удостоверяющим центром;
- ведение реестра выданных и аннулированных этим удостоверяющим центром сертификатов;
- создание по обращениям заявителей ключей;
- проверка уникальности открытых ключей в реестре сертификатов;
- осуществление проверок электронных подписей (по обращению участников электронного взаимодействия).

В РФ предусмотрена аккредитация удостоверяющих центров под началом головного удостоверяющего центра Минцифры России, т. е. формируется иерархия удостоверяющих центров. [Список аккредитованных удостоверяющих центров](#) доступен на веб-сайте Минцифры России. При этом для внутренних нужд в организации может быть создан не аккредитованный удостоверяющий центр.

Пример сертификата аккредитованного удостоверяющего центра представлен ниже:



Аккредитованные удостоверяющие центры выпускают квалифицированные сертификаты для создания усиленной квалифицированной электронной подписи.

Данные сертификаты содержат:

- уникальный номер квалифицированного сертификата;
- даты начала и окончания его действия;

- Ф.И.О. владельца сертификата – для физлица, либо наименование и место нахождения владельца сертификата – для юрлица;
- СНИЛС владельца сертификата – для физлица, либо ИНН владельца сертификата – для юрлица;
- ключ проверки электронной подписи (открытый ключ);
- наименование используемого средства электронной подписи (СКЗИ);
- наименования аккредитованного удостоверяющего центра;
- наименование и место нахождения аккредитованного удостоверяющего центра;
- идентификатор, однозначно указывающий на то, что идентификация заявителя при выдаче сертификата проводилась либо при его личном присутствии, либо без его личного присутствия.

Электронный документ, подписанный квалифицированной электронной подписью, признаётся равнозначным бумажному документу, подписанному собственноручной подписью, при следующих условиях:

- сертификат создан и выдан аккредитованным удостоверяющим центром (действующим);
- сертификат действителен на момент подписания электронного документа или на день проверки, если момент подписания не определён;
- имеется положительный результат проверки принадлежности владельцу сертификата, с помощью которой подписан электронный документ, и подтверждено отсутствие изменений, внесённых в этот документ после его подписания;
- электронная подпись используется в соответствии с учётом ограничений, содержащихся в сертификате (не нарушает ограничений, если они есть): хотя данный пункт утратил силу с 1 июля 2020 года, он имеет практическую ценность.

Использование явных ограничений позволяет избежать ситуаций, когда атакующий, скомпрометировавший один закрытый ключ и уже имеющий на руках открытый ключ в сертификате, пытается применить его во всех возможных ситуациях (подписывает всё подряд, аутентифицируется везде подряд и т. п.). В качестве примеров ограничений использования сертификатов можно привести следующие:

- цифровая подпись;
- шифрование ключей;
- проверка подлинности клиента;

- проверка подлинности сервера;
- подписывание кода;
- защищённая электронная почта;
- шифрующая файловая система (EFS);
- вход со смарт-картой;
- специализированные:
 - формирование запроса о предоставлении сведений из Единого государственного реестра ...;
 - только для использования в системах сдачи отчетности с ФНС ...

К причинам аннулирования (отзыва) сертификата можно отнести следующие:

- компрометация или подозрение на компрометацию закрытого ключа;
- компрометация центра сертификации (удостоверяющего центра);
- прекращение работы (увольнение работника);
- отмена привилегии;
- замена сертификата;
- ошибка в сертификате.

При запросе на аннулирование (отзыв) сертификата обязательно указывается дата и время отзыва, в случае необходимости (зачастую компрометации) необходимо указать «немедленно».

Заключение по блоку инфраструктур открытых ключей:

- инфраструктура открытых ключей – это большая отдельная прикладная область в криптографии;
- в основе инфраструктуры открытых ключей лежат:
 - асимметричное шифрование;
 - хэширование;
- выпущенные сертификаты имеют срок действия, т.е. работа с ними – это процесс, а не разовое мероприятие.

Практика применения криптографической защиты информации

Средства криптографической защиты информации (СКЗИ)

В соответствии с действующим законодательством [6] к шифровальным (криптографическим) средствам (средствам криптографической защиты информации (СКЗИ)) относятся:

- средства шифрования – аппаратные, программные и программно-аппаратные шифровальные (криптографические) средства, реализующие алгоритмы криптографического преобразования информации для ограничения доступа к ней, в т.ч. при её хранении, обработке и передаче;
- средства имитозащиты – аппаратные, программные и программно-аппаратные шифровальные (криптографические) средства (за исключением средств шифрования), реализующие алгоритмы криптографического преобразования информации для её защиты от навязывания ложной информации, в т. ч. защиты от модифицирования, для обеспечения её достоверности и не корректируемости, а также обеспечения возможности выявления изменений, имитации, фальсификации или модифицирования информации;
- средства электронной подписи - шифровальные (криптографические) средства, используемые для реализации хотя бы одной из следующих функций - создание электронной подписи, проверка электронной подписи, создание ключа электронной подписи (закрытый ключ) и ключа проверки электронной подписи (открытый ключ);
- средства кодирования – средства шифрования, в которых часть криптографических преобразований информации осуществляется с использованием ручных операций или с использованием автоматизированных средств, предназначенных для выполнения таких операций;
- средства изготовления ключевых документов – аппаратные, программные, программно-аппаратные шифровальные (криптографические) средства, обеспечивающие возможность изготовления ключевых документов для шифровальных (криптографических) средств, не входящие в состав этих шифровальных (криптографических) средств;
- ключевые документы – электронные документы на любых носителях информации, а также документы на бумажных носителях, содержащие ключевую информацию ограниченного доступа для криптографического преобразования информации с использованием алгоритмов

- криптографического преобразования информации (криптографический ключ) в шифровальных (криптографических) средствах;
- аппаратные шифровальные (криптографические) средства – устройства и их компоненты, в т. ч. содержащие ключевую информацию, обеспечивающие возможность преобразования информации в соответствии с алгоритмами криптографического преобразования информации без использования программ для ЭВМ;
 - программные шифровальные (криптографические) средства – программы для ЭВМ и их части, в т.ч. содержащие ключевую информацию, обеспечивающие возможность преобразования информации в соответствии с алгоритмами криптографического преобразования информации в программно-аппаратных шифровальных (криптографических) средствах, информационных системах и телекоммуникационных системах, защищённых с использованием шифровальных (криптографических) средств;
 - программно-аппаратные шифровальные (криптографические) средства – устройства и их компоненты (за исключением информационных систем и телекоммуникационных систем), в т.ч. содержащие ключевую информацию, обеспечивающие возможность преобразования информации в соответствии с алгоритмами криптографического преобразования информации с использованием программ для ЭВМ, предназначенных для осуществления этих преобразований информации или их части.

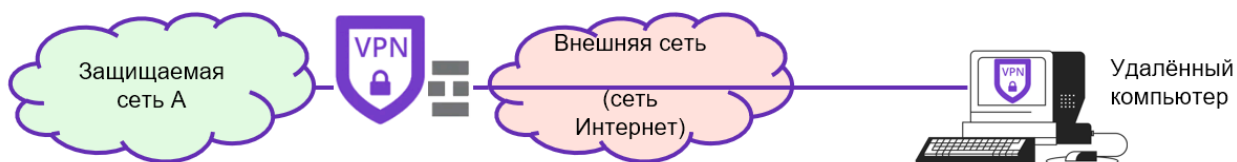
Практика применения СКЗИ

Подавляющее большинство организаций применяют СКЗИ для защиты каналов связи с применением технологии «Виртуальных частных сетей» (Virtual Private Network (VPN)), которая зачастую представлена двумя схемами практической реализации:

- Site-to-Site: схема защиты сетевого трафика, циркулирующего между двумя и более площадками:



- Client-to-Site: схема защиты сетевого трафика, циркулирующего между площадкой и одним и более удалёнными компьютерами:



Встречаются и их комбинации. В данных схемах применяются так называемые криптошлюзы (VPN-шлюзы), которые иногда совмещаются с межсетевыми экранами, и программные VPN-клиенты (абонентские пункты) для удалённых компьютеров.

Если нет потребности шифровать весь сетевой трафик между площадками или отдельными компьютерами, то может применяться шифрование данных при передаче для определённых приложений, например:

- веб-трафик;
- электронная почта;
- аудио- или видеоконференции;
- мессенджеры.

Отдельным примером практического применения СКЗИ является шифрование данных при хранении:

- полнодисковое шифрование (Full Disk Encryption);
- шифрование отдельных каталогов или файлов;
- шифрование в составе программного обеспечения (базы данных).

Сведения о наиболее популярных средствах для хранения закрытых ключей (секретных ключей) приведены в таблице ниже:

Тип устройства	Достоинства	Недостатки
USB-накопитель	Не требуется считывающее устройство	Не обеспечивают защиту информации
Token	Не требуется считывающее устройство, высокая функциональность	-
iButton	Высокая надёжность, долговечность, работа в критических условиях	Требуется считывающее устройство, низкая функциональность

Локальный Hardware Security Module	Не требуется считывающее устройство, высокая функциональность, обслуживание всех пользователей, высокий уровень безопасности ключей	Единая точка отказа
Облачный Hardware Security Module	Не требуется считывающее устройство, высокая функциональность, обслуживание всех пользователей, высокий уровень доступности	Уровень доверия к поставщику услуги



Защита закрытых ключей на съёмном носителе:

- не передавать носитель третьим лицам;
- не подключать носитель к компьютерам, не предназначенным для осуществления электронного взаимодействия;
- не знакомить с содержанием носителя лиц, к нему не допущенных (выводить информацию на принтер);
- не записывать на носитель постороннюю информацию.

К причинам компрометации закрытых ключей (секретных ключей) можно отнести следующие:

- потеря носителя с закрытым ключом (секретным ключом);
- потеря носителя с закрытым ключом (секретным ключом) с его последующим обнаружением;
- нарушение правил хранения носителя с закрытым ключом (секретным ключом);
- возникновение подозрений на утечку информации или её искажение;
- случаи, когда нельзя достоверно установить, что произошло с носителем (в т. ч. случаи, когда носитель вышел из строя и не опровергнута возможность того, что данный факт произошёл в результате несанкционированных действий).

Атаки на криптосистемы

К основным классам атак на криптосистемы можно отнести следующие:

- атаки с использованием только шифртекста (Ciphertext Only Attacks): современные криптосистемы защищены от таких атак;
- атаки с использованием открытого текста (Known Plaintext Attacks): у дешифровщика есть образец открытого текста и шифртекста, что может позволить ему восстановить ключ;
- атаки с использованием избранного открытого текста (Chosen Plaintext Attacks): дешифровщик может зашифровать выбранный им текст, получит пару “открытый текст и шифртекст”, что может позволить ему восстановить ключ;
- атаки «грубой силы» (Brute-Force Attacks): дешифровщик перебирает все возможные ключи, здесь он ограничен только доступными вычислительными ресурсами;
- атаки «человек посередине» (Man-in-the-Middle Attacks): дешифровщик выступает шлюзом между получателями сообщений, расшифровывая и шифруя их сообщения и выдавая себя за целевого собеседника;
- атака по побочному каналу (Side Channel Attacks): дешифровщик анализирует особенность физической реализации криптосистемы (например, потребление электроэнергии и т.п.);
- атаки по времени (Timing Attacks): дешифровщик анализирует время вычислений (например, если шифрование занимает больше времени, это указывает на то, что секретный ключ длинный);
- анализ ошибок (Fault Analysis Attacks): дешифровщик создаёт ошибки в работе криптосистемы и анализирует полученные результаты на наличие полезной информации.

Плюс, отдельно стоит отметить эксплуатацию уязвимостей:

- в программной реализации алгоритмов шифрования;
- в процедурах проверки сертификатов.

Современные протоколы шифрования

К наиболее популярным современным протоколам шифрования, но без протоколов аутентификации², можно отнести:

- Secure Socket Layer (SSL) / Transport Level Security (TLS): протокол для шифрования и аутентификации с использованием сертификатов (особенно популярен в веб-трафике (HTTPS));

² Рассматривались отдельно.

🔥 Все версии протокола SSL устарели и не являются безопасными на сегодняшний день. Хотя, к сожалению, очень часто упоминаются и используются. Не применяйте их в своей практике! Действующими является TLS 1.2 и TLS 1.3.

- Secure Shell (SSH): протокол для шифрования и аутентификации в рамках удалённых подключений к системам (особенно популярен в Linux-окружении);
- Secure/Multipurpose Internet Mail Extensions (S/MIME): протокол для шифрования сообщений электронной почты;
- Point to Point Tunneling Protocol (PPTP): VPN-протокол для соединения точка-точка;
- Internet Protocol Security (IPsec): группа VPN-протоколов, включающих:
 - Authentication Header (AH): протокол аутентификации и целостности передаваемых данных;
 - Encapsulating Security Payload (ESP): протокол шифрования данных;
 - Internet Key Exchange (IKE): протокол обмена ключами;
- Протоколы туннелирования:
 - Generic Routing Encapsulation (GRE);
 - Layer 2 Forwarding Protocol (L2F);
 - Layer 2 Tunneling Protocol (L2TP).

🔥 Протоколы туннелирования не шифруют данные, но рассматриваются совместно с другими VPN-протоколами.

Дополнительные сопутствующие протоколы:

- Online Certificate Status Protocol (OCSP): протокол для онлайн-получения статуса отзыва сертификата;
- Time-Stamp Protocol (TSP): протокол получения штампов времени.

Заключение по блоку практика применения криптографической защиты информации:

- СКЗИ разнообразны и могут применяться для решения различных задач;
- обеспечение безопасности закрытых ключей (секретных ключей) является основой для обеспечения конфиденциальности шифруемых данных;
- существуют уязвимости как в шифрах, так и в их реализации (протоколах шифрования, конкретных СКЗИ).

Система сертификации средств криптографической защиты информации и особенности применения на территории РФ

Цель проведения сертификации СКЗИ – это получение подтверждения соответствия СКЗИ требованиям ГОСТ и ФСБ России, которое даёт потребителям возможность применять данное средство и проводить оценку соответствия систем требованиям безопасности информации (аттестацию) с использованием СКЗИ.

Пример сертификата соответствия на СКЗИ с указанием его ключевых элементов приведён ниже:

ФЕДЕРАЛЬНАЯ СЛУЖБА БЕЗОПАСНОСТИ
РОССИЙСКОЙ ФЕДЕРАЦИИ

Система сертификации РОСС RU.0001.030001

СЕРТИФИКАТ СООТВЕТСТВИЯ

Регистрационный номер **СФ/124-4219** от "22" февраля 2022 г.

Действителен до "15" марта 2024 г.

Выдан обществу с ограниченной ответственностью «Код Безопасности»

Настоящий сертификат удостоверяет, что изделие «Аппаратно-программный комплекс шифрования «Континент». Версия 3.9» (исполнение 1) в комплектации согласно формуляру RU.88338853.501430.022.30

соответствует Требованиям к средствам криптографической защиты информации, предназначенным для защиты информации, не содержащей сведений, составляющих государственную тайну, класса КС2 и может использоваться для криптографической защиты (создание и управление ключевой информацией, шифрование и дешифрование данных, передаваемых и IP-пакетах по общим сетям передачи данных) информации, не содержащей сведений, составляющих государственную тайну.

Сертификат выдан на основании результатов проведенных обществом с ограниченной ответственностью «Код Безопасности» и обществом с ограниченной ответственностью «АНСЕР ПРО» сертификационных испытаний образца продукции № 794E1-001001.

Безопасность информации обеспечивается при использовании изделия в соответствии с требованиями эксплуатационной документации согласно формуляру RU.88338853.501430.022.30.

Заместитель руководителя Научно-технической службы – начальник Центра защиты информации и специальной связи ФСБ России О.В. Скрабин

срок действия

требования

организации участники

ФСБ России

Сертификация производится на соответствие классам СКЗИ, в основе которых лежит модель нарушителя применительно к данным СКЗИ:

- КС1: нарушитель может проводить атаку только из-за пределов контролируемой зоны;
- КС2: нарушитель может проводить атаку в пределах контролируемой зоны, но без физического доступа к аппаратным средствам, на которых реализованы СКЗИ;

- КСЗ: нарушитель может проводить атаку в пределах контролируемой зоны с физическим доступом к аппаратным средствам, на которых реализованы СКЗИ;
- КВ: нарушитель может располагать исходными текстами прикладных программ, входящих в среду функционирования и взаимодействующих со СКЗИ;
- КА: нарушитель имеет возможность доступа к любому аппаратному компоненту СКЗИ, в т.ч. может использовать закладки.

Особенности использования СКЗИ, регламентируются нормативно-методическими документами ФСБ России [8,9]. Из ключевого стоит отметить:

- обязательную физическую защиту помещений со СКЗИ;
- эксплуатацию СКЗИ в строгом соответствии с правилами пользования;
- поэкземплярный учёт СКЗИ, документации на них, а также допущенных лиц;
- обучение лиц, использующих СКЗИ, правилам работы с ними;
- контроль за соблюдением условий использования СКЗИ.

К основным российским производителям VPN-решений можно отнести:

- «ИнфоТеКС» (ViPNet);
- «Код Безопасности» (Континент);
- «С-Терра» (С-Терра);
- «Элвис-Плюс» (Застава).

 К сожалению, в большинстве случаев VPN-решения различных российских производителей несовместимы между собой. Таким образом, выбор конкретного производителя и архитектурного решения должен быть обоснован.

К основным российским производителям криптопровайдеров (Cryptography Service Provider (CSP)), которые выступают «крипто-движком», можно отнести:

- «КРИПТО-ПРО» (КриптоПро CSP);
- «Лисси» (LISSI-CSP);
- «ИнфоТеКС» (ViPNet CSP);
- «Сигнал-КОМ» (Signal-COM CSP);
- «ВАЛИДАТА» (Сигнатура);
- «МО ПНИЭИ» (Верба-OW).

Заключение по блоку особенности применения СКЗИ на территории РФ:

- если в нормативных документах заявляется криптографическая защита информации, то допускаются к использованию только сертифицированные СКЗИ;
- использование сертифицированных СКЗИ предусматривает дополнительные организационные и технические мероприятия (физическая безопасность, учёт и т.д.);
- отечественный рынок сертифицированных СКЗИ ограничен, требуется:
 - проверка совместимости с общесистемным и прикладным ПО;
 - оценка негативного влияния на производительность (задержки при передаче информации);
 - дополнительная квалификация для администрирования СКЗИ.

Выводы

- Криптография является отдельным направлением в области обеспечения информационной безопасности
- Существуют различные алгоритмы шифрования и их реализации:
 - Симметричные для шифрования данных.
 - Асимметричные для обмена ключами (для последующего симметричного шифрования) и создания / проверки электронной подписи.
- На территории РФ разработка (производство) и применение СКЗИ ограничены сертифицированными средствами и регулируются ФСБ России (в части системы сертификации) и Минцифра России (в части инфраструктуры открытых ключей).

Дополнительные материалы

1. Фильм «[Игра в имитацию](#)», 2014 г.
2. Книга «Семь безопасных информационных технологий», Александр Баронов и др., 2017 г.
3. Статья «[Установка и настройка СКЗИ](#)», Александр Веселов.
4. Статья «[Шифруем по-русски, или отечественные криптоалгоритмы](#)».
5. Цикл статей «[Погружение в крипто](#)».

Использованная литература

1. Статья «[История криптографии](#)», Д.А. Лузгин, А.Р. Гамилов, О.И. Свиридов, 2018 г.
2. Статья «[Анализ текстов](#)».
3. ГОСТ 34.12-2018 «[Информационная технология. Криптографическая защита информации. Блочные шифры](#)».
4. ГОСТ 34.10-2018 «[Информационная технология. Криптографическая защита информации. Процессы формирования и проверки электронной цифровой подписи](#)».
5. ГОСТ 34.11-2018 «[Информационная технология. Криптографическая защита информации. Функция хэширования](#)».
6. [Федеральный закон от 06.04.2011 N 63-ФЗ «Об электронной подписи](#)».
7. [Положению о лицензировании деятельности по разработке, производству, распространению шифровальных \(криптографических\) средств ...](#), утв. постановление Правительства РФ от 16.04.2012 N 313.
8. [Положения о разработке, производстве, реализации и эксплуатации шифровальных \(криптографических\) средств защиты информации](#), утв. приказом ФСБ России от 09.02.2005 N 66.
9. [Инструкции об организации и обеспечении безопасности хранения, обработки и передачи по каналам связи с использованием средств криптографической защиты информации с ограниченным доступом, не содержащей сведений, составляющих государственную тайну](#), утв. приказом ФАПСИ от 13.06.2001 N 152.